

的操作系统或计算机的 IP 地址，不需要保证网络上所有计算机的物理安全性，并且假定数据包在传输中可被随机窃取和篡改。

Kerberos 的安全机制在于首先对发出请求的用户进行身份验证，确认其是否是合法的用户；如是合法的用户，再审核该用户是否有权对其所请求的服务或计算机进行访问。从加密算法上来讲，其验证是建立在对称加密的基础上的，KDC 保存与所有密钥持有者通信的保密密钥，其认证过程颇为复杂。

4. 外壳脚本机制

外壳脚本机制通过原始认证进入系统外壳，然后外壳就会激发各种专用平台的脚本，来激活目标平台的账号和资源的访问。这种方式简化了用户的登录，但它没有提供同步的口令字以及其他管理方法。

9.4 系统访问控制技术

访问控制技术是系统安全防范和保护的主要核心策略，它的主要任务是保证系统资源不被非法使用和访问。访问控制规定了主体对客体访问的限制，并在身份识别的基础上，根据身份对提出资源访问的请求加以控制。

9.4.1 访问控制概述

访问控制是策略（policy）和机制（mechanism）的集合，它允许对限定资源的授权访问。访问控制技术也可以保护资源，防止那些无权访问资源的用户的恶意访问。访问控制是系统安全保障机制的核心内容，是实现数据保密性和完整性机制的主要手段，也是计算机系统中最重要和最基础的安全机制。

1. 访问控制的要素

访问控制包括三个要素，分别是主体、客体和控制策略。

（1）主体。主体是可以对其他实体施加动作的主动实体，有时也称为用户或访问者（被授权使用计算机的人员）。主体的含义是宽泛的，可以是用户所在的组织、用户本身，也可以是用户使用的计算机终端和手持终端（无线终端）等，甚至可以是应用服务程序或进程。

（2）客体。客体是接受其他实体访问的被动实体。客体的概念也很宽泛，凡是可以被操作的信息、资源和对象都可以认为是客体。在信息社会中，客体可以是信息、文件和记录等的集合体，也可以是网络上的硬件设施和无线通信中的终端等。

（3）控制策略。控制策略是主体对客体的操作行为集合约束条件集（访问规则集），直接定义了主体对客体的作用行为和客体对主体的条件约束。访问策略体现了一种授权行为，也就是客体对主体的权限允许，这种允许不超越规则集。

2. 访问控制的策略

访问控制策略包括登录访问控制、操作权限控制、目录安全控制、属性安全控制和服务器